Meilenstein 05 – AuthKit: Sicherheits- und Web-Härtung, Frontend-CI und Release v1.0.0

Feld	Wert
Projekt	Overex
Zeitraum	2026-10-11 – 2026-10-12
Dokumentiert am	2026-10-12 05:56 CEST
Repository / Service	`authkit` (github.com/Umex10/authkit): Backend `apps/backend` , Web-Client `apps/web` , CI, Image `ghcr.io/umex10/authkit-backend`
Thema	Keine selbst gewählte Admin-Rolle, React-Native-App entfernt, Sitzungs- und Token-Handling im Frontend repariert, stabile Frontend-Tests, CI für das Frontend, versionierte Docker-Images, Release `v1.0.0`
Commits	11 (`596fe06` .. `7fb315a`), Branch `feature/web-hardening` , lokal per `--no-ff` nach `main` gemergt (`99defc7`), danach Merge des Doku-Branches (`7fb315a`), Tag `v1.0.0` auf `7fb315a`
Zeitaufwand	nicht erfasst
Bezug	Projektarbeit (5. Semester) und Grundlage für die Bachelorarbeit (6. Semester); Abschluss des ersten Microservices (Auth)

Ziel

AuthKit sollte als erster Microservice von Overex fertig werden: das ganze Auth-System sicher und benutzerfreundlich, die Next.js-App als Referenz-Client, deren Sign-up/Sign-in-Code ich später nach Overex übernehme, alles durch Tests und CI abgesichert und als versioniertes Docker-Image veröffentlicht. Die React-Native-App habe ich gestrichen, weil ich sie weder für AuthKit noch für Overex brauche.

Ausgangslage

- Das Sign-up-Formular hatte eine Rollen-Auswahl, und das Backend übernahm die Rolle ungeprüft: Jeder konnte sich als `ADMIN` registrieren.
- Ein Refresh-Cookie, das das Backend ablehnt, ließ den Nutzer auf einem leeren Dashboard stecken; `/sign-in` leitete wegen des vorhandenen Cookies zurück.
- Der Access-Token wurde nur beim Laden geholt; nach 15 Minuten scheiterte jeder Request.
- Die E2E-Tests liefen nur dank Wiederholungen (in zwei Läufen 3 bzw. 2 von 6 „flaky“); `npm run test:e2e` meldete immer Erfolg.
- Die Web-Unit-Tests prüften nur einen CSS-Helfer und zwei Anzeige-Komponenten.
- Es gab keine CI für das Frontend; `docker-publish` taggte Images mit `sha-<commit>` .
- Ein alter Release enthielt eine APK der React-Native-App; M02/M03 lagen nur auf dem Branch `docs/meilenstein-doku` .

Umsetzung (chronologisch)

1. **2026-10-11** – Backend: Sign-up ohne Rollenfeld, jedes neue Konto ist `USER` ; `Role` -Enum nach `common/entities` ; E-Mails getrimmt und kleingeschrieben; Passwort mindestens 8 Zeichen, Sign-in ohne Längenregel (`596fe06`).
2. **2026-10-11** – `apps/mobile` gelöscht (55 Dateien), `.gitignore` und `docker-ci` bereinigt (`70c40ef`).
3. **2026-10-11** – Web: `AuthProvider` löscht ein abgelehntes Cookie und leitet nach `/sign-in?session=expired` ; `baseQueryWithReauth` erneuert den Access-Token bei 401 und wiederholt den Request; Store pro Tab; Submit erst nach Hydration aktiv, Formulare mit `method="post"` und `noValidate` ; Regeln und Cookie-Parsing in `lib/` ; Cookie in Produktion `Secure` ; `any` entfernt (`75e2509`).
4. **2026-10-11** – Tests: E2E neu (12 Specs, Produktions-Build auf 3001, `.next-e2e` , keine lokalen Retries, echter Exit-Code), 4 neue Vitest-Dateien (`3505bf1`).
5. **2026-10-11** – Doku: Mobile entfernt, neue Sicherheitsregeln, Abschnitt zum Übernehmen der Auth-Dateien in eine andere Next.js-App (`814dd33`).

6. **2026-10-12** – CI: `web-build-ci`, `web-unit-ci` (JUnit-Report über `vitest.config.ts`), `web-e2e-ci`; Ausnahme der Integrationstests in `backend-verify-ci` entfernt (`8e976e9`).
7. **2026-10-12** – Neue Screenshots ohne Rollen-Auswahl (`873ae69`).
8. **2026-10-12** – `docker-publish` taggt bei Versions-Tags mit `1.0.0`, `1.0`, `1`, `latest` statt `sha-…` (`edb419c`).
9. **2026-10-12** – `docs/CI.md`, Badges und Abschnitt zum Image in der README (`32845ee`).
10. **2026-10-12** – Merge nach `main` (`99defc7`), Merge des Meilenstein-Doku-Branches (`7fb315a`), alle 5 Workflows auf `main` grün.
11. **2026-10-12** – Tag `v1.0.0`, Image-Tags auf ghcr.io veröffentlicht, GitHub-Release „AuthKit v1.0.0“; alter Release `dev-client-v1` samt Tag gelöscht (laut Entscheidung des Users).

Geänderte Dateien

Datei	Art	Zweck
`apps/backend/.../common/entities/Role.java`	neu	Rollen-Enum bei der Entity statt im Sign-up-DTO
`apps/backend/.../auth/dto/requests/SignUpAccountRequestDto.java`	geändert	kein `role`-Feld, Passwort ≥ 8
`apps/backend/.../auth/dto/requests/SignInAccountRequestDto.java`	geändert	keine Längenregel beim Sign-in
`apps/backend/.../auth/AuthService.java`	geändert	Rolle immer `USER`, E-Mail-Normalisierung
`apps/backend/.../common/entities/User.java`, `user/dto/UserResponseDto.java`	geändert	neuer Import des Enums
`apps/backend/src/test/...` (BackendApplicationTests, AuthServiceTest, TestDataFactory)	geändert	Admin direkt in der DB; Tests für ignorierte Rolle und Groß-/Kleinschreibung
`apps/mobile/**`	gelöscht	React-Native-App entfernt (55 Dateien)
`apps/web/components/AuthProvider.tsx`	geändert	abgelehnte Sitzung → Cookie löschen, `/sign-in?session=expired`
`apps/web/redux/api/apiSlice.ts`	geändert	`baseQueryWithReauth`: bei 401 Token erneuern, Request einmal wiederholen
`apps/web/redux/api/apis/auth.ts`	geändert	Typen, `upsertQueryData` nach Login
`apps/web/redux/store.ts`, `StoreProvider.tsx`	geändert	Store-Fabrik, ein Store pro Tab
`apps/web/actions/auth-action.ts`	geändert	gemeinsame Fehlerbehandlung, `Secure` in Produktion, kein `role`
`apps/web/app/sign-up/page.tsx`, `app/sign-in/page.tsx`	geändert	ohne Rollen-Auswahl, Hydration-Sperre, POST, `noValidate`, Hinweis „Session expired“
`apps/web/lib/validation.ts`, `lib/refresh-cookie.ts`, `lib/use-hydrated.ts`, `types/ApiError.ts`	neu	Formular-Regeln, Cookie-Parsing, Hydration-Hook, Fehlertyp
`apps/web/components/fun/Celebration.tsx`, `SignOutButton.tsx`, `app/(shell)/dashboard/page.tsx`	geändert	Lint-Fehler behoben, Test-ID

`apps/web/__tests__/e2e/*`	neu/gelöscht	`signed-out.spec.ts`, `signed-in.spec.ts`, Hilfen; altes Spec und `getTestData` gelöscht
`apps/web/__tests__/unit/*.test.ts`	neu	validation, refresh-cookie, proxy, reauth
`apps/web/playwright.config.ts`, `package.json`, `next.config.ts`, `tsconfig.json`, `eslint.config.mjs`, `vitest.config.ts`	geändert	E2E-Setup (3001, `.next-e2e`), Skripte, Reports, Ignore-Liste
`.github/workflows/web-build-ci.yml`, `web-unit-ci.yml`, `web-e2e-ci.yml`	neu	CI für das Frontend
`.github/workflows/backend-verify-ci.yml`, `docker-ci.yml`, `docker-publish.yml`	geändert	Integrationstests wieder an; Kommentar; Versions-Tags
`.gitignore`	geändert	Expo-Einträge entfernt, `.next-e2e/` und `test-reports/`
`README.md`, `docs/*.md`, `docs/CI.md` (neu), `docs/screenshots/*`	geändert/neu	Doku, Badges, Release-Ablauf, neue Screenshots

Entscheidungen

Entscheidung	**Verworfene Alternativen**	**Begründung**
Backend vergibt immer `USER` (Entscheidung des Users)	nur Frontend ändern; als Demo lassen	eine Prüfung nur im Frontend ließe sich per direktem API-Aufruf umgehen
E-Mail trimmen im Frontend, kleinschreiben im Backend	alles im Backend	`@Email` lehnt Leerzeichen schon vor dem Service ab
React-Native-App löschen (Entscheidung des Users)	behalten	wird weder für AuthKit noch für Overex gebraucht
`baseQueryWithReauth` um `fetchBaseQuery`	Token per Timer erneuern; Seite neu laden lassen	wirkt für alle Endpoints mit `query`, auch nach einem Schlafzustand des Tabs; empfohlenes RTK-Muster
Eine gemeinsame Erneuerung für parallele 401	jeder Request erneuert selbst	sonst mehrere Refresh-Aufrufe für dieselbe Sache
Submit erst nach Hydration + `method="post" + noValidate`	nur Retries in den Tests	behebt die Ursache der Flakiness und verhindert ein Passwort in der URL
E2E gegen Produktions-Build auf 3001 in `.next-e2e`	`next dev` auf 3000	schneller, stabiler, näher an Produktion; kollidiert nicht mit dem Dev-Server
Keine Retries lokal	`retries: 1`	ein Test, der erst beim zweiten Mal grün wird, versteckt einen Fehler
Vitest-Reporter in `vitest.config.ts` (Wunsch des Users)	nur im Workflow	Reports entstehen lokal und in CI gleich; Workflow ruft nur `npm run test:unit`
Drei Frontend-Workflows (Wunsch des Users)	ein Workflow mit zwei Jobs + E2E separat (meine Empfehlung)	einheitlich mit dem Backend: eine Datei pro Aufgabe; E2E braucht ohnehin eigene Auslöser
`npm ci` und `setup-node` mit `cache: npm`	`npm install`	prüft Lockfile gegen `package.json`, verändert nichts, reproduzierbar
Semver-Image-Tags statt `sha-…` (Wunsch des Users)	SHA-Tags	Releases sind über die Versionsnummer abrufbar

Version `v1.0.0` (Entscheidung des Users)	`v2.0.0`, `v0.1.0`	erster vollständiger Stand
Screenshots gegen Test-Backend auf Port 8080	Dev-Datenbank; Test-Backend auf 8081	keine Dev-Daten im Bild, Port passend zur README

Neu gelernt

- **`baseQuery` / `fetchBaseQuery` / `prepareHeaders`**: `createApi` verlangt eine Funktion, die Requests verschickt; `fetchBaseQuery` baut sie, `prepareHeaders` läuft vor jedem Senden. Eine eigene Hülle darum kann nach der Antwort reagieren und neu senden.
- **`query` vs. `queryFn`**: Mit `query` verschickt die `baseQuery` den Request; mit `queryFn` macht der Endpoint alles selbst (bei uns über Server Actions), die `baseQuery` wird übersprungen.
- **`createApi` einmal, `injectEndpoints` mehrfach**: ein gemeinsamer Cache und eine `baseQuery` für alle Endpoints.
- **`onQueryStarted` und `upsertQueryData`**: nach erfolgreichem Login den Token direkt in den Cache-Eintrag von `getAccessTk` legen.
- **`package.json` vs. `package-lock.json`**: erlaubte Bereiche vs. exakt installierte Versionen (mit Prüfsummen); `npm ci` installiert nur aus der Lockfile und bricht bei Abweichungen ab.
- **GitHub-Actions-Cache**: ein Speicher pro Repo; `setup-node` sichert `~/.npm` unter einem Namen aus dem Hash der Lockfile.
- **Lint vs. Type check**: ESLint findet riskante Muster (Stufen `warn` / `error`), `tsc --noEmit` prüft nur Typen. `next build` prüft die Typen der App, aber nicht die Testdateien (im Versuch bestätigt).
- **Was `next build` macht**: transpilieren, Typen prüfen, bündeln, verkleinern, Server- und Client-Code trennen, Seiten vorrendern, `NEXT_PUBLIC_*` einbacken.
- **Hydration**: Vor der Hydration ist eine Seite nur HTML; Klicks verpuffen, und ein Formular wird notfalls vom Browser selbst abgeschickt.
- **Docker-Build**: `FROM` startet nichts; jedes `RUN` läuft in einem kurzlebigen Container; bei Multi-Stage gelangt nur die letzte Stufe ins Image.

Tests & Verifikation

Test	Ergebnis
`./mvnw verify`	67 Tests grün
Vitest (`npm run test:unit`)	27 Tests grün, `test-reports/junit.xml` erzeugt
Playwright (`npm run test:e2e`)	12/12 beim ersten Versuch, lokal 5 Läufe ohne Flakiness
`npm run typecheck`, `npm run lint`	fehlerfrei
Manueller Durchlauf im Browser (Dev-Stack)	Registrieren, `/me`-Daten mit Rolle `USER`, Neuladen, Abmelden, falsches Passwort, Großschreibung der E-Mail, manipuliertes Cookie: alles wie erwartet
CI auf `feature/web-hardening` (`8e976e9`)	4 Workflows grün, Backend erstmals mit Integrationstests
CI auf `main` (`7fb315a`)	5 Workflows grün inkl. `docker-publish`
`docker-publish` für `v1.0.0`	grün; Tags `1.0.0`, `1.0`, `1`, `latest` auf ghcr.io abrufbar, anonymer Pull möglich

Probleme & Lösungen

- **Problem:** Jeder konnte sich als Admin registrieren. → **Lösung:** Rollenfeld entfernt, Backend vergibt `USER`, Test für eine eingeschmuggelte Rolle.
- **Problem:** E2E-Flakiness (Checkbox-Klick vor der Hydration). → **Lösung:** Submit erst nach Hydration aktiv, Produktions-Build, Hilfsfunktionen warten auf aktive Buttons.
- **Problem:** Formular wurde nicht abgeschickt, weil `type="email"` die Browser-Prüfung auslöste. → **Lösung:** `noValidate`.

- **Problem:** Der Unit-Test zur Token-Erneuerung fand, dass nach gescheiterter Erneuerung mit dem alten Token wiederholt wurde. → **Lösung:** Erfolg nur bei `data` und ohne `error`.
- **Problem:** `@Email` lehnt E-Mails mit Leerzeichen ab, bevor das Backend normalisiert. → **Lösung:** Trimmen im Frontend.
- **Problem:** `npm run test:e2e` lieferte immer Exit-Code 0. → **Lösung:** Exit-Code von Playwright merken und am Ende zurückgeben.
- **Problem:** Über 3000 Lint-Meldungen, fast alle aus `playwright-report`. → **Lösung:** generierte Ordner in der ESLint-Ignore-Liste, echte Fehler im Code behoben.
- **Problem:** Zufalls-Telefonnummern in den E2E-Konten konnten kollidieren. → **Lösung:** Ende der ID (Prozess-ID, Zähler) statt des Anfangs.
- **Problem:** `next build` schrieb `.next-e2e` in die `tsconfig.json`. → **Lösung:** Einträge committet.
- **Problem:** `backend-verify-ci` schloss die Integrationstests weiterhin aus. → **Lösung:** Ausnahme entfernt.
- **Problem:** M02/M03 schienen verschwunden. → **Lösung:** Sie lagen auf `docs/meilenstein-doku`; Branch nach `main` gemergt.

Eingesetzte Hilfsmittel

Claude Code (Anthropic). Die Backend- und Frontend-Änderungen, die Tests, die Screenshots, `web-build-ci.yml`, die Doku und die Release-Notes hat Claude auf meine Anfrage geschrieben; ich habe die Konzepte (RTK `baseQuery`, npm-Lockfile, CI-Cache, Lint, Type check, `next build`) Schritt für Schritt erklärt bekommen. `web-e2e-ci.yml` und `web-unit-ci.yml` habe ich selbst begonnen, Claude hat sie geprüft und vervollständigt. Die Entscheidungen zur Admin-Rolle, zum Löschen der Mobile-App, zur Version und zum alten Release habe ich getroffen. Commits mit meiner Git-Identität. (FH-Richtlinien zur Kennzeichnung beachten.)

Offene Punkte / Nächste Schritte

- Overex: Sign-up/Sign-in-Code aus `apps/web` übernehmen (Dateiliste in `docs/CUSTOMIZING.md`).
- Nächster Microservice: Tokens per `jwk-set-uri` prüfen, inklusive `type_tk == ACCESS`-Validator.
- Vor Produktion: Rate Limiting auf `/auth/**`, Refresh-Token-Rotation, Plattform für das Deployment (Railway oder Secrets als Dateien).
- In der Dev-Datenbank liegt der Test-Nutzer `manual-1791749895531@authkit.test` aus dem manuellen Test.

Commit-Verlauf

Datum	Hash	Nachricht	Inhalt (kurz)
2026-10-11 22:02	`596fe06`	fix(auth): never let sign-up choose a role; normalize emails	Rolle immer `USER`, `Role`-Enum verschoben, E-Mail-Normalisierung, Passwort ≥ 8
2026-10-11 22:19	`70c40ef`	chore: remove the React Native app	`apps/mobile` gelöscht, Reste in `.gitignore` und `docker-ci`
2026-10-11 22:19	`75e2509`	fix(web): recover from dead sessions and harden the auth forms	Session-Recovery, Token-Erneuerung, Hydration/POST/`noValidate`, Store pro Tab, `lib/`
2026-10-11 22:19	`3505bf1`	test(web): stable e2e suite for the whole auth flow; unit tests for the logic	12 E2E-Specs auf 3001, 4 neue Vitest-Dateien, echter Exit-Code
2026-10-11 22:21	`814dd33`	docs: web-only setup, new security rules and the reworked tests	Doku ohne Mobile, neue Regeln, Übernahme in andere Apps
2026-10-12 05:38	`8e976e9`	ci: add build, unit and e2e workflows for the web app	drei Frontend-Workflows, Integrationstests im Backend-CI wieder an
2026-10-12 05:53	`873ae69`	docs: new screenshots without the role select	Desktop- und Handy-Screenshots neu
2026-10-12 05:53	`edb419c`	ci(docker): tag published images with the release version	Semver-Tags statt `sha-…`
2026-10-12 05:53	`32845ee`	docs: CI workflows, published image and release process	`docs/CI.md`, Badges, Image-Abschnitt
2026-10-12 05:53	`99defc7`	Merge branch 'feature/web-hardening'	Merge nach `main`

2026-10-12 05:53	`7fb315a`	Merge branch 'docs/meilenstein-doku'	Meilenstein-Doku M01–M03 auf `main` ; Tag `v1.0.0`